

JOBSHEET 2

Asset, Threat, Vulnerability dan Risk

Mata kuliah	Keamanan Perangkat Lunak
Pertemuan	2
Topik	Asset, Threat, Vulnerability & Risk, pengenalan CWE dan CVSS
Praktikum	Identifikasi aset, threat, vulnerability dan risk pada Juice Shop; skoring CVSS sederhana
Output	Asset & Risk Register
Dosen pengampu	Muhammad Asep Subandri, M.Kom
Nama Kelompok	Nurani (6304240055) Sulestari (6304240033)

A. Tujuan Praktikum

Setelah menyelesaikan jobsheet ini, mahasiswa mampu:

- Mengidentifikasi dan mengklasifikasikan aset sebuah aplikasi web.
- Mengidentifikasi threat beserta threat actor-nya.
- Mengamati kemungkinan vulnerability secara pasif dan memetakannya ke CWE.
- Menghitung risk dengan $\text{likelihood} \times \text{impact}$ dan menyusun Asset & Risk Register.
- Memberi skor CVSS sederhana pada tiga temuan teratas.

B. Alat dan Bahan

Komponen	Keterangan
Target	OWASP Juice Shop dari pertemuan 1 (http://localhost:3000).
Pengamatan	Browser DevTools dan History pada OWASP ZAP.
Kalkulator CVSS	first.org/cvss/calculator/3.1
Katalog CWE	cwe.mitre.org
Template	Tabel pada Lampiran A dan B jobsheet ini.

C. Dasar Teori Singkat

1. Aset, threat, vulnerability, risk

Aset adalah segala sesuatu yang bernilai dan harus dilindungi. **Vulnerability** adalah kelemahan pada aset atau kontrolnya. **Threat** adalah pihak atau kejadian yang berpotensi memanfaatkan kelemahan. **Risk** adalah kombinasi peluang terjadinya kerugian (likelihood) dan besarnya kerugian (impact).

2. Skala penilaian pada praktikum ini

Komponen	Skala
Nilai aset (C, I, A)	1 = rendah, 2 = sedang, 3 = tinggi. Nilai aset = nilai tertinggi dari ketiganya.
Likelihood (L)	1 = sangat jarang, 2 = jarang, 3 = mungkin, 4 = sering, 5 = hampir pasti.
Impact (I)	1 = kecil, 2 = ringan, 3 = sedang, 4 = berat, 5 = sangat berat.
Skor risk	$L \times I$. Rendah 1–4, Sedang 5–9, Tinggi 10–14, Kritis 15–25.

3. CWE, CVE, dan CVSS

- **CWE** (Common Weakness Enumeration): katalog jenis kelemahan perangkat lunak, misalnya CWE-89 untuk SQL Injection.
- **CVE** (Common Vulnerabilities and Exposures): identitas unik kerentanan yang diketahui pada produk tertentu, misalnya CVE-2021-44228 (Log4Shell).
- **CVSS** (Common Vulnerability Scoring System): skor keparahan 0–10. Severity: Rendah 0.1–3.9, Sedang 4.0–6.9, Tinggi 7.0–8.9, Kritis 9.0–10.0.

CVSS tidak sama dengan risk

CVSS menilai keparahan teknis sebuah kerentanan. Risk memperhitungkan nilai aset, kemungkinan terjadi, dan konteks bisnis. Satu temuan dengan CVSS tinggi dapat berisiko rendah bila aset yang terdampak tidak penting, dan sebaliknya.

D. Langkah Praktikum

Batasan hari ini

Praktikum ini hanya **mengamati**. Eksploitasi aktif (SQL injection, XSS, dan sejenisnya) belum dilakukan dan baru dipelajari pada pertemuan berikutnya. Tetap patuhi Rules of Engagement dari pertemuan 1.

Langkah 1. Memetakan sistem

1. Pastikan container Juice Shop berjalan (docker ps), lalu buka <http://localhost:3000>.
2. Jelajahi aplikasi sebagai pengguna biasa: daftarkan satu akun milik Anda sendiri, login, cari produk, tambahkan ke keranjang, dan lihat profil.

3. Tulis satu paragraf deskripsi sistem yang memuat: tujuan aplikasi, aktor (pengunjung, pelanggan, admin), fitur utama, dan jenis data yang diproses.

Langkah 2. Mengidentifikasi aset

1. Daftarkan minimal **10 aset** dari kategori Data, Software, Infrastruktur, Manusia, serta Reputasi dan proses.
2. Isi tabel pada Lampiran A: ID, aset, kategori, serta nilai C, I, dan A (skala 1–3).
3. Hitung nilai aset dari nilai tertinggi C, I, dan A.

Contoh baris:

ID	Aset	Kategori	C	I	A	Nilai aset
A-01	Data akun pengguna (email, hash password)	Data	3	3	2	3 (tinggi)

Langkah 3. Mengidentifikasi threat

1. Daftarkan minimal **8 threat**. Setiap threat harus menyebut aktor dan aset yang diancam.
2. Pertimbangkan aktor berikut: penyerang eksternal, insider berniat jahat, bot otomatis, kesalahan tidak sengaja, dan supply chain.

Contoh: T-01, penyerang eksternal mengambil alih akun pelanggan (aset A-01).

Langkah 4. Mengamati vulnerability secara pasif

Lakukan pemeriksaan berikut dan catat setiap hasilnya sebagai **hipotesis kerentanan** beserta bukti (screenshot atau potongan request/response).

Pengamatan	Kemungkinan temuan	CWE terkait
Login dengan password salah berulang kali pada akun milik Anda sendiri (sekitar 10 kali). Apakah ada pembatasan, penguncian, atau CAPTCHA?	Tidak ada pembatasan percobaan login	CWE-307
Daftarkan akun uji dengan password sangat lemah, misalnya "12345". Apakah diterima?	Kebijakan password lemah	CWE-521
Kirim input tidak valid atau akses alamat yang tidak ada. Apakah error menampilkan detail teknis (path, stack trace, versi)?	Informasi teknis pada pesan error	CWE-209
Periksa response header di DevTools atau ZAP. Adakah Content-Security-Policy dan X-Content-Type-Options?	Header pengaman tidak lengkap	CWE-693
Periksa Cookies dan Local Storage. Di mana token sesi disimpan? Apakah cookie memiliki flag HttpOnly?	Penyimpanan token kurang aman	CWE-1004, CWE-922
Perhatikan identifier pada URL atau API (misalnya nomor keranjang). Catat pola identifier tanpa mengubahnya .	Hipotesis akses objek milik pengguna lain (diuji pada pertemuan 7)	CWE-639

Pengamatan	Kemungkinan temuan	CWE terkait
Telusuri file JavaScript klien. Adakah rute atau informasi internal yang terbuka?	Informasi sensitif di sisi klien	CWE-200

Rincian setiap CWE dapat dibaca pada <https://cwe.mitre.org/data/definitions/<nomor>.html> (ganti <nomor> dengan angka CWE, misalnya 307). Anda boleh menambahkan temuan lain di luar tabel di atas bila ada buktinya.

Langkah 5. Menghitung risk

1. Untuk setiap temuan, tentukan Likelihood (1–5) dan Impact (1–5) beserta alasan singkat.
2. Hitung skor dengan rumus $L \times I$ dan tentukan kategorinya (Rendah, Sedang, Tinggi, Kritis).
3. Hubungkan setiap baris ke ID aset dan ID threat, lalu urutkan dari skor tertinggi.

Contoh perhitungan:

Temuan : login tanpa pembatasan percobaan (CWE-307)
Aset : A-01 data akun pengguna (nilai 3)
Likelihood : 4 (bot credential stuffing mudah dijalankan)
Impact : 4 (akun pelanggan dapat diambil alih)
Skor risk : $4 \times 4 = 16 \rightarrow$ Kritis

Langkah 6. Memberi skor CVSS

1. Pilih **tiga temuan dengan skor risk tertinggi**.
2. Buka kalkulator CVSS v3.1 pada first.org/cvss/calculator/3.1.
3. Isi metrik Base (AV, AC, PR, UI, S, C, I, A) sesuai kondisi temuan, lalu catat skor dan vector string.
4. Tulis alasan pemilihan nilai setiap metrik dalam satu kalimat.

Contoh vector string (SQL injection pada login tanpa autentikasi):
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H $\rightarrow$ 9.8 (Kritis)

AV:N dapat diserang melalui jaringan
AC:L tidak butuh kondisi khusus
PR:N tidak butuh hak akses awal
UI:N tidak butuh interaksi korban
S:U dampak terbatas pada komponen yang sama
C/I/A:H dampak tinggi pada ketiganya

Langkah 7. Menyusun register final

1. Gabungkan hasil Langkah 2–6 ke tabel Lampiran B (Asset & Risk Register).
2. Pastikan setiap baris memiliki ID unik (R-01, R-02, dan seterusnya), karena register ini dilanjutkan pada pertemuan 4 dan 13.
3. Tulis refleksi 3–4 kalimat: mengapa temuan dengan CVSS tertinggi belum tentu menjadi risk tertinggi?

E. Output dan Pengumpulan

Seluruh output menjadi **Bab 2** pada laporan berjalan. Kumpulkan dalam satu file PDF dengan nama NIM_Nama_Bab2.pdf.

No	Bagian laporan	Isi
1	Deskripsi sistem	Satu paragraf: tujuan, aktor, fitur, dan data.
2	Tabel aset	Minimal 10 aset dengan nilai C, I, A.
3	Tabel threat	Minimal 8 threat dengan aktor dan aset terkait.
4	Asset & Risk Register	Minimal 8 baris dengan CWE, L, I, skor, dan kategori.
5	Skor CVSS	Tiga temuan teratas beserta vector string dan alasan.
6	Refleksi	Perbedaan CVSS dan risk, 3–4 kalimat.

F. Rubrik Penilaian

Komponen	Kriteria utama	Bobot
Deskripsi sistem	Lengkap dan sesuai hasil penjelajahan	10
Aset dan klasifikasi	Minimal 10 aset, kategori dan nilai CIA masuk akal	20
Threat	Minimal 8, aktor dan aset terhubung jelas	15
Risk register dan CWE	Pemetaan CWE tepat, skor $L \times I$ konsisten dan beralasan	25
Skor CVSS	Vector string benar dan didukung alasan	20
Refleksi dan kerapian	Pemahaman perbedaan CVSS dan risk, laporan rapi	10
Total		100

G. Referensi

- MITRE, Common Weakness Enumeration (cwe.mitre.org).
- FIRST, CVSS v3.1 Specification Document (first.org/cvss).
- OWASP Risk Rating Methodology (owasp.org).
- NIST SP 800-30, Guide for Conducting Risk Assessments.

Deskripsi Sistem

OWASP Juice Shop merupakan aplikasi web yang digunakan sebagai target pembelajaran keamanan perangkat lunak untuk mengamati berbagai aspek keamanan pada aplikasi web. Sistem ini dapat diakses oleh beberapa aktor, yaitu pengunjung, pelanggan, dan admin. Fitur utama yang dapat diamati meliputi pendaftaran dan login akun, pencarian produk, melihat katalog produk, menambahkan produk ke keranjang, melihat profil, serta fungsi administrasi. Data yang diproses oleh sistem meliputi data akun pengguna seperti email dan hash password, data produk dan harga, data pesanan, serta data yang berkaitan dengan proses operasional aplikasi. Dalam praktikum ini, Juice Shop diamati untuk mengidentifikasi aset, threat, dan kemungkinan vulnerability secara pasif tanpa melakukan eksploitasi aktif.

Lampiran A. Template Tabel Aset dan Threat

Tabel aset

ID	Aset	Kategori	C	I	A	Nilai aset
A-01	Data akun pengguna (email dan hash password)	Data	3	3	2	3 (Tinggi)
A-02	Data pesanan dan alamat pengiriman	Data	3	2	2	3 (Tinggi)
A-03	Katalog produk dan harga	Data	1	3	2	3 (Tinggi)
A-04	Data keranjang belanja pengguna	Data	2	2	2	2 (Sedang)
A-05	Layanan storefront web	Software	1	2	3	3 (Tinggi)
A-06	Halaman dan fungsi admin	Software	3	3	2	3 (Tinggi)
A-07	Kode sumber dan file konfigurasi	Software	3	3	1	3 (Tinggi)
A-08	Container/server Juice Shop	Infrastruktur	2	2	3	3 (Tinggi)
A-09	Akun admin, developer, dan pengguna	Manusia	3	3	2	3 (Tinggi)
A-10	Kepercayaan pengguna dan operasional layanan	Reputasi & proses	2	3	3	3 (Tinggi)

Tabel threat

ID	Threat	Aktor	Aset terkait
T-01	Pengambilalihan akun pengguna melalui percobaan login berulang	Bot otomatis	A-01 Data akun pengguna

ID	Threat	Aktor	Aset terkait
T-02	Pencurian data akun pengguna melalui serangan dari luar	Penyerang eksternal	A-01 Data akun pengguna
T-03	Akses atau perubahan data pesanan tanpa hak	Penyerang eksternal	A-02 Data pesanan dan alamat pengiriman
T-04	Manipulasi harga atau informasi produk	Insider berniat jahat	A-03 Katalog produk dan harga
T-05	Penyalahgunaan keranjang belanja pengguna	Penyerang eksternal	A-04 Data keranjang belanja
T-06	Gangguan terhadap layanan web sehingga tidak dapat digunakan	Penyerang eksternal	A-05 Layanan storefront web
T-07	Penyalahgunaan hak akses pada fungsi administrasi	Insider berniat jahat	A-06 Halaman dan fungsi admin
T-08	Kebocoran atau perubahan kode sumber dan konfigurasi	Kesalahan tidak sengaja / supply chain	A-07 Kode sumber dan file konfigurasi

Lampiran B. Template Asset & Risk Register

ID	Aset	Threat	Vulnerability	CWE	L	I	Skor	Kategori	CVSS (bila ada)
R-01	A-01 Data akun pengguna	T-01 Bot otomatis mengambil alih akun	Login tanpa pembatasan percobaan	CWE-307	4	4	16	Kritis	
R-02	A-01 Data akun pengguna	T-02 Penyerang eksternal mencuri akun	Kebijakan password lemah	CWE-521	4	4	16	Kritis	
R-03	A-05 Layanan storefront web	T-02 Penyerang eksternal memperoleh informasi sistem	Informasi teknis pada pesan error	CWE-209	3	3	9	Sedang	
R-04	A-05 Layanan storefront web	T-06 Penyerang eksternal menyerang aplikasi web	Header pengaman tidak lengkap	CWE-693	3	3	9	Sedang	
R-05	A-01 Data akun pengguna	T-02 Penyerang eksternal mencuri token sesi	Penyimpanan token sesi kurang aman	CWE-922	4	4	16	Kritis	
R-06	A-02 Data pesanan dan alamat pengiriman	T-03 Penyerang eksternal mengakses objek pengguna lain	Akses objek berdasarkan identifier yang berpotensi tidak terlindungi	CWE-639	3	5	15	Kritis	
R-07	A-07 Kode sumber dan file konfigurasi	T-08 Kebocoran kode atau konfigurasi	Informasi sensitif di sisi klien	CWE-200	3	4	12	Tinggi	
R-08	A-01 Data akun pengguna	T-02 Penyerang eksternal mencuri sesi pengguna	Cookie sesi tidak memiliki flag HttpOnly	CWE-1004	3	4	12	Tinggi	

Screenshot response CWE-307:

https://cwe.mitre.org/data/definitions/307.html

CWE20 Common Weakness Enumeration
Celebrating 20 years of community-developed cybersecurity weakness knowledge!

Home > CWE List > CWE-307: Improper Restriction of Excessive Authentication Attempts (4.20)

Home About Learn Access Content Community Search

CWE-307: Improper Restriction of Excessive Authentication Attempts

Weakness ID: 307
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description

The product does not implement sufficient measures to prevent multiple failed authentication attempts within a short time frame.

Common Consequences

https://cwe.mitre.org/data/images/CWE-307-Diagram.png

Screenshot response CWE-521:

https://cwe.mitre.org/data/definitions/521.html

CWE20 Common Weakness Enumeration
Celebrating 20 years of community-developed cybersecurity weakness knowledge!

Home > CWE List > CWE-521: Weak Password Requirements (4.20)

Home About Learn Access Content Community Search

CWE-521: Weak Password Requirements

Weakness ID: 521
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description

The product does not require that users should have strong passwords.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity	Scope: Access Control An attacker could easily guess user passwords and gain access user accounts.

Potential Mitigations

Phase(s)	Mitigation
----------	------------

Screenshot response CWE-209:

Common Weakness Enumeration

CWE-209: Generation of Error Message Containing Sensitive Information (4.20)

Weakness ID: 209
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description

The product generates an error message that includes sensitive information about its environment, users, or associated data.

File not found: /app/settings.dat
Could not connect to DB server.
User:admin; password:mySekret

ERROR

Screenshot response CWE-693:

Common Weakness Enumeration

CWE-693: Protection Mechanism Failure (4.20)

Weakness ID: 693
Vulnerability Mapping: DISCOURAGED
Abstraction: Pillar

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description

The product does not use or incorrectly uses a protection mechanism that provides sufficient defense against directed attacks against the product.

Extended Description

This weakness covers three distinct situations. A "missing" protection mechanism occurs when the application does not define any mechanism against a certain class of attack. An "insufficient" protection mechanism might provide some defenses - for example, against the most common attacks - but it does not protect against everything that is intended. Finally, an "ignored" mechanism occurs when a mechanism is available and in active use within the product, but the developer has not applied it in some code path.

Common Consequences

Impact Details

Bypass Protection Mechanism Scope: Access Control

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
MemberOf	✓	1000	Research Concepts
ParentOf	ⓘ	184	Incomplete List of Disallowed Inputs
ParentOf	✓	311	Missing Encryption of Sensitive Data

Screenshot response CWE-922:

CWE-922: Insecure Storage of Sensitive Information

Weakness ID: 922
Vulnerability Mapping: **ALLOWED** (with careful review of mapping notes)
Abstraction: Class

View customized information:

Description
The product stores sensitive information without properly limiting read or write access by unauthorized actors.

Extended Description
If read access is not properly restricted, then attackers can steal the sensitive information. If write access is not properly restricted, then attackers can modify and possibly delete the data, causing incorrect results and possibly a denial of service.

Common Consequences

Impact	Details
Read Application Data; Read Files or Directories	Scope: Confidentiality Attackers can read sensitive information by accessing the unrestricted storage mechanism.
Modify Application Data; Modify Files or Directories	Scope: Integrity Attackers can overwrite sensitive information by accessing the unrestricted storage mechanism.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	I-P	664	Improper Control of a Resource Through its Lifetime
ParentOf	B	312	Cleartext Storage of Sensitive Information
ParentOf	B	921	Storage of Sensitive Data in a Mechanism without Access Control

Relevant to the view "Weaknesses for Simplified Mapping of Published Vulnerabilities" (View-1003)

Nature	Type	ID	Name
MemberOf	V	1003	Weaknesses for Simplified Mapping of Published Vulnerabilities

Screenshot response CWE-639:

← × https://cwe.mitre.org/data/definitions/639.html

CWE20 Common Weakness Enumeration
Celebrating 20 years of community-developed cybersecurity weakness knowledge!

Home > CWE List > CWE-639: Authorization Bypass Through User-Controlled Key (4.20)

Home | About | Learn | Access Content | Community | Search

CWE-639: Authorization Bypass Through User-Controlled Key

Weakness ID: 639
Vulnerability Mapping: **ALLOWED**
Abstraction: Base

View customized information:

Description
The system's authorization functionality does not prevent one user from gaining access to another user's data or record by modifying the key value identifying the data.

Extended Description
Retrieval of a user record occurs in the system based on some key value that is under user control. The key would typically identify a user-related record stored in the system and would be used to lookup that record for presentation to the user. It is likely that an attacker would have to be an authenticated user in the system. However, the authorization process would not properly check the data access operation to ensure that the authenticated user performing the operation has sufficient entitlements to perform the requested data access, hence bypassing any other authorization checks present in the system.

For example, attackers can look at places where user specific data is retrieved (e.g. search screens) and determine whether the key for the item being looked up is controllable externally. The key may be a hidden field in the HTML form field, might be passed as a URL parameter or as an unencrypted cookie variable, then in each of these cases it will be possible to tamper with the key value.

One manifestation of this weakness is when a system uses sequential or otherwise easily-guessable session IDs that would allow one user to easily switch to another user's session and read/modify their data.

Alternate Terms

Insecure Direct Object Reference / IDOR	The "Insecure Direct Object Reference" term, as described in the OWASP Top Ten, is broader than this CWE because it also covers path traversal (CWE-22). Within the context of vulnerability theory, there is a similarity between the OWASP concept and CWE-706: Use of Incorrectly-Resolved Name or Reference.
Broken Object Level Authorization / BOLA	BOLA is used in the 2019 OWASP API Security Top 10 and appears to have some overlap, but BOLA may be applicable to other weaknesses in addition to this one.

Screenshot response CWE-200:

Common Weakness Enumeration

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor (4.20)

Weakness ID: 200
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description

The product exposes sensitive information to an actor that is not explicitly authorized to have access to that information.

Extended Description

There are many different kinds of mistakes that introduce information exposures. The severity of the error can range widely, depending on the context in which the product operates, the type of sensitive information that is revealed, and the benefits it may provide to an attacker. Some kinds of sensitive information include:

- private, personal information, such as personal messages, financial data, health records, geographic location, or contact details
- system status and environment, such as the operating system and installed packages
- business secrets and intellectual property
- network status and configuration
- the product's own code or internal state
- metadata, e.g. logging of connections or message headers
- indirect information, such as a discrepancy between two internal operations that can be observed by an outsider

Information might be sensitive to different parties, each of which may have their own expectations for whether the information should be protected. These parties include:

- the product's own users
- people or organizations whose information is created or used by the product, even if they are not direct product users
- the product's administrators, including the admins of the system(s) and/or networks on which the product operates
- the developer

Screenshot response CWE-1004:

Common Weakness Enumeration

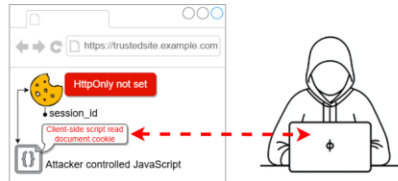
CWE-1004: Sensitive Cookie Without 'HttpOnly' Flag (4.20)

Weakness ID: 1004
Vulnerability Mapping: ALLOWED
Abstraction: Variant

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description

The product uses a cookie to store sensitive information, but the cookie is not marked with the HttpOnly flag.



Common Consequences

Impact	Details
Read Application Data	Scope: Confidentiality If the HttpOnly flag is not set, then sensitive information stored in the cookie may be exposed to unintended parties. Scope: Integrity

SKOR CVSS

R-01 — Login tanpa pembatasan percobaan

CWE-307: Improper Restriction of Excessive Authentication Attempts

Metrik:

Metrik	Nilai	Alasan
AV	N (Network)	Serangan dapat dilakukan melalui jaringan terhadap layanan login.
AC	L (Low)	Tidak memerlukan kondisi khusus untuk melakukan percobaan login berulang.

PR	N (None)	Penyerang tidak memerlukan hak akses sebelumnya.
UI	N (None)	Tidak membutuhkan interaksi dari korban.
S	U (Unchanged)	Dampak tetap berada pada komponen aplikasi yang rentan.
C	H (High)	Pengambilalihan akun dapat menyebabkan informasi akun korban terbaca.
I	H (High)	Akun yang berhasil diambil alih dapat disalahgunakan untuk mengubah data atau aktivitas akun.
A	N (None)	Temuan ini tidak secara langsung menyebabkan layanan menjadi tidak tersedia.

Vector String:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Base Score: 9.1 — Kritis

R-02 — Kebijakan password lemah

CWE-521: Weak Password Requirements

Metrik:

Metrik	Nilai	Alasan
AV	N (Network)	Password digunakan untuk autentikasi melalui aplikasi web yang dapat diakses melalui jaringan.
AC	L (Low)	Password yang lemah dapat meningkatkan kemudahan percobaan autentikasi.
PR	N (None)	Penyerang tidak memerlukan hak akses sebelumnya untuk mencoba memperoleh akun.
UI	N (None)	Tidak membutuhkan interaksi korban pada saat serangan dilakukan.
S	U (Unchanged)	Dampak berada pada komponen aplikasi yang sama.
C	H (High)	Jika akun berhasil diperoleh, informasi pengguna dapat terekspos.
I	H (High)	Akun yang berhasil diperoleh dapat digunakan untuk melakukan perubahan terhadap data atau aktivitas akun.
A	N (None)	Kelemahan password tidak secara langsung menyebabkan layanan berhenti.

Vector String:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Base Score: 9.1 — Kritis

R-05 — Penyimpanan token sesi kurang aman

CWE-922: Insecure Storage of Sensitive Information

Metrik:

Metrik	Nilai	Alasan
AV	N (Network)	Dampak dapat terjadi pada konteks aplikasi web yang berkomunikasi melalui jaringan.
AC	L (Low)	Tidak diperlukan kondisi khusus apabila token dapat diperoleh melalui mekanisme yang rentan.
PR	N (None)	Penyerang tidak memerlukan hak akses sebelumnya untuk memanfaatkan kelemahan yang menjadi dasar temuan.
UI	R (Required)	Pada skenario ini diperlukan interaksi pengguna agar token/sesi dapat terekspos atau dimanfaatkan.
S	U (Unchanged)	Dampak tetap berada pada komponen aplikasi yang sama.
C	H (High)	Token sesi dapat memberikan akses terhadap informasi akun pengguna.
I	H (High)	Penyalahgunaan token sesi dapat memungkinkan tindakan sebagai pengguna yang bersangkutan.
A	N (None)	Tidak secara langsung menyebabkan layanan menjadi tidak tersedia.

Vector String:

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

CVSS Base Score: 8.1 — Tinggi

REFLEKSI

CVSS dan risk memiliki tujuan penilaian yang berbeda. **CVSS digunakan untuk menilai tingkat keparahan teknis suatu vulnerability**, sedangkan **risk mempertimbangkan kemungkinan terjadinya (likelihood) dan dampak (impact) terhadap aset**. Oleh karena itu, vulnerability dengan CVSS tinggi belum tentu menjadi risk tertinggi karena nilai risk juga dipengaruhi oleh kondisi dan nilai aset yang terdampak. Dengan demikian, CVSS dapat digunakan sebagai salah satu pertimbangan, tetapi penilaian risk tetap perlu melihat konteks aset dan kemungkinan terjadinya ancaman.